☠ HACKER'S FIELD NOTES ☠

SCANNING & ENUMERATION

Complete Practical Reference | Ethical Hacking & CEH/OSCP Prep

01. SCANNING & ENUMERATION — THE PHASE

Scanning and Enumeration is Phase 2 of ethical hacking, coming after Reconnaissance. The goal is to actively probe the target network and systems to identify live hosts, open ports, running services, OS versions, and extract detailed information that feeds exploitation decisions.

KEY DIFFERENCE:

- Scanning → What's alive, what ports are open, what services run
- Enumeration → Extract specific info: usernames, shares, policies, banners

> **[!] WARNING:** Only perform scanning & enumeration on systems you own or have WRITTEN authorization to test. Unauthorized scanning is illegal under the Computer Fraud and Abuse Act (CFAA) and similar laws worldwide.

02. TYPES OF SCANNING

▶ 2.1 Network Scanning

Identifies live hosts on a network segment. Sends packets and analyzes responses.

- Ping Sweep (ICMP scan) — simplest form
- ARP Scan — works only on local subnet, most reliable on LAN
- TCP/UDP Port Scans — probe individual ports per host

▶ 2.2 Port Scanning

Identifies which TCP/UDP ports are open, closed, or filtered on a target host.

State	Meaning	Indicator
OPEN	Port is listening, service running	SYN-ACK received
CLOSED	Port accessible but no service	RST received

State	Meaning	Indicator
FILTERED	Firewall dropping/blocking packets	No response or ICMP unreachable
UNFILTERED	Port accessible, state unknown	ACK scan result
OPEN|FILTERED	Can't determine — no response	UDP / FIN scans

▶ 2.3 Vulnerability Scanning

Automated tools probe for known vulnerabilities — misconfigs, outdated software, weak credentials, missing patches.

- Tools: Nessus, OpenVAS, Nikto, Nuclei

03. NMAP — THE SCANNER'S BIBLE

Nmap (Network Mapper) is the most powerful and widely used open-source network scanner. Used by hackers, defenders, and sysadmins alike.

▶ 3.1 Basic Syntax

```
nmap [Scan Type] [Options] {target}
nmap 192.168.1.1                    # Basic scan (1000 common ports)
nmap 192.168.1.0/24                 # Scan entire subnet
nmap 192.168.1.1-50                 # Scan IP range
nmap -iL targets.txt                # Scan from file
```

▶ 3.2 Host Discovery

```
nmap -sn 192.168.1.0/24             # Ping sweep (no port scan)
nmap -Pn 192.168.1.1                # Skip host discovery, treat as up
nmap -PE 192.168.1.0/24             # ICMP echo ping
nmap -PS22,80,443 192.168.1.1       # TCP SYN ping on specific ports
nmap -PA80 192.168.1.1              # TCP ACK ping
nmap -PU53 192.168.1.1              # UDP ping
```

[TIP] Use -Pn when target blocks ICMP. Many firewalls drop pings but leave ports accessible.

▶ 3.3 Port Scanning Techniques

Flag	Scan Type	Description	Privilege
-sS	TCP SYN (Stealth)	Half-open scan. Doesn't complete handshake. Fast & stealthy.	Root

Flag	Scan Type	Description	Privilege
-sT	TCP Connect	Full 3-way handshake. Logged by target. No root needed.	User
-sU	UDP Scan	Scans UDP ports. Slow. Important for DNS/SNMP/TFTP.	Root
-sF	FIN Scan	Sends FIN packet. Bypasses some firewalls.	Root
-sX	Xmas Scan	FIN+PSH+URG flags. Stealthy against older systems.	Root
-sN	Null Scan	No flags set. Bypasses some firewalls.	Root
-sA	ACK Scan	Maps firewall rules, NOT open ports.	Root
-sW	Window Scan	Similar to ACK, checks TCP window size.	Root
-sM	Maimon Scan	FIN/ACK combo. Works on BSD systems.	Root

▶ 3.4 Port Specification

```
nmap -p 80 192.168.1.1              # Single port
nmap -p 80,443,8080 192.168.1.1     # Multiple ports
nmap -p 1-1000 192.168.1.1          # Port range
nmap -p- 192.168.1.1                # ALL 65535 ports
nmap -p U:53,T:80,443 192.168.1.1  # UDP and TCP mix
nmap --top-ports 100 192.168.1.1    # Top 100 common ports
```

▶ 3.5 Service & OS Detection

```
nmap -sV 192.168.1.1                # Service version detection
nmap -sV --version-intensity 9 192.168.1.1  # Max intensity (slower)
nmap -O 192.168.1.1                 # OS detection (requires root)
nmap -O --osscan-guess 192.168.1.1 # Aggressive OS guess
nmap -A 192.168.1.1                 # Aggressive: OS+version+scripts+traceroute
```

[TIP] -A is the go-to for CTFs and pentest reports. Combines -sV -O -sC --traceroute

▶ 3.6 Nmap Scripting Engine (NSE)

NSE scripts are Lua scripts that extend Nmap's functionality massively. Scripts live in /usr/share/nmap/scripts/

```
nmap -sC 192.168.1.1                            # Default scripts
nmap --script=http-title 192.168.1.1            # Specific script
nmap --script=smb-vuln-* 192.168.1.1           # All SMB vuln scripts
nmap --script=vuln 192.168.1.1                 # All vuln scripts
nmap --script=auth 192.168.1.1                 # Auth bypass scripts
nmap --script=http-enum 192.168.1.1            # Web directory enum
nmap --script=banner 192.168.1.1               # Grab banners
```

```
nmap --script=smtp-enum-users 192.168.1.1         # SMTP user enum
nmap -p 445 --script=smb-os-discovery 192.168.1.1
```

NSE Script Categories:

- auth — Authentication related
- broadcast — Discover hosts by broadcasting
- brute — Brute force attacks
- discovery — Host/service discovery
- dos — Denial of service tests
- exploit — Exploit vulnerabilities
- external — Use external services/APIs
- fuzzer — Fuzzing attacks
- intrusive — Likely to crash services
- malware — Detect malware
- safe — Won't crash services
- version — Extended version detection
- vuln — Check for known vulnerabilities

▶ 3.7 Timing & Performance

Flag	Template	Speed	Use Case
-T0	Paranoid	Very Slow	IDS evasion
-T1	Sneaky	Slow	IDS evasion
-T2	Polite	Slow	Low bandwidth
-T3	Normal (default)	Normal	Standard scanning
-T4	Aggressive	Fast	Good network / CTFs
-T5	Insane	Very Fast	LAN only, may miss results

```
nmap -T4 --min-rate 1000 --max-retries 3 192.168.1.0/24
```

▶ 3.8 Evasion & Firewall Bypass

```
nmap -f 192.168.1.1                    # Fragment packets
nmap --mtu 16 192.168.1.1              # Custom MTU (multiple of 8)
nmap -D RND:10 192.168.1.1             # Decoy scan (10 random IPs)
nmap -D 10.0.0.1,10.0.0.2,ME 192.168.1.1  # Custom decoys
nmap -S 10.0.0.5 192.168.1.1           # Spoof source IP
nmap --source-port 53 192.168.1.1      # Spoof source port
nmap --data-length 25 192.168.1.1      # Append random data
nmap --randomize-hosts 192.168.1.0/24  # Random host order
nmap --scan-delay 2s 192.168.1.1       # Delay between probes
```

▶ 3.9 Output Formats

```
nmap -oN output.txt 192.168.1.1       # Normal text output
nmap -oX output.xml 192.168.1.1       # XML output
nmap -oG output.gnmap 192.168.1.1     # Grepable output
nmap -oA output 192.168.1.1           # All formats at once
nmap -v 192.168.1.1                   # Verbose
nmap -vv 192.168.1.1                  # Very verbose
```

▶ 3.10 Ninja One-Liners

```
# Full recon on a host
nmap -A -T4 -p- -oA full_scan 192.168.1.1
```

```
# Quick host discovery then deep scan
nmap -sn 192.168.1.0/24 -oG - | awk '/Up/{print $2}' > live.txt && nmap -iL
live.txt -sV -sC -oA deep
```

```
# Stealth SYN scan with decoys
nmap -sS -T2 -f -D RND:5 --source-port 53 192.168.1.1
```

```
# SMB vulnerability check
nmap -p 445 --script=smb-vuln-ms17-010,smb-vuln-ms08-067 192.168.1.0/24
```

04. ENUMERATION — SERVICE BY SERVICE

Enumeration goes deep into discovered services to extract actionable intelligence: usernames, shares, version strings, SNMP data, DNS records, and more.

▶ 4.1 DNS Enumeration

DNS is a goldmine. It can reveal subdomains, mail servers, zone transfers, and internal hostnames.

◈ Basic DNS Queries

```
nslookup target.com
dig target.com ANY                    # All DNS records
dig target.com MX                     # Mail servers
dig target.com NS                     # Name servers
dig target.com TXT                    # TXT records (SPF, DKIM, etc)
dig +short target.com A               # Just the IP
```

◈ Zone Transfer (AXFR)

```
dig axfr @ns1.target.com target.com   # Full zone transfer
```

```
host -l target.com ns1.target.com     # Alternative zone transfer
```

[TIP] Zone transfers dump all DNS records. Misconfigured DNS servers leak entire internal DNS structure!

◈ Subdomain Bruteforce

```
dnsenum target.com
dnsrecon -d target.com -t brt -D /usr/share/wordlists/dnsmap.txt
gobuster dns -d target.com -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
subfinder -d target.com -o subs.txt
amass enum -d target.com
```

▶ 4.2 SMB Enumeration (Port 139/445)

SMB (Server Message Block) is a critical enumeration target — often yields shares, usernames, OS info, and sometimes EternalBlue (MS17-010).

◈ Null Session / Guest Access

```
smbclient -L //192.168.1.1 -N              # List shares, no password
smbclient //192.168.1.1/share -N           # Connect anonymously
net use \\192.168.1.1\IPC$ '' /u:''       # Windows null session
```

◈ enum4linux — The SMB Enumerator

```
enum4linux -a 192.168.1.1                  # Full enum: users, shares, groups
enum4linux -u '' -p '' -a 192.168.1.1      # Explicit null session
enum4linux -u admin -p password -a 192.168.1.1
```

◈ smbmap — Map Shares

```
smbmap -H 192.168.1.1                      # List shares
smbmap -H 192.168.1.1 -u '' -p ''          # Null auth
smbmap -H 192.168.1.1 -u admin -p pass123  # Authenticated
smbmap -H 192.168.1.1 -R                   # Recursive listing
```

◈ CrackMapExec (CME) — Swiss Army Knife

```
crackmapexec smb 192.168.1.0/24            # Spray the subnet
crackmapexec smb 192.168.1.1 -u admin -p pass
crackmapexec smb 192.168.1.1 --shares      # List shares
crackmapexec smb 192.168.1.1 --users       # List users
crackmapexec smb 192.168.1.1 --rid-brute   # RID brute for users
```

◈ Nmap SMB Scripts

```
nmap -p 139,445 --script=smb-enum-shares,smb-enum-users 192.168.1.1
```

```
nmap -p 445 --script=smb-vuln-ms17-010 192.168.1.1   # EternalBlue check
nmap -p 445 --script=smb-security-mode 192.168.1.1   # SMB signing check
```

▶ 4.3 SNMP Enumeration (Port 161/UDP)

SNMP (Simple Network Management Protocol) leaks system info: running processes, interfaces, software, user accounts, routing tables.

◈ Community String Brute

```
onesixtyone -c /usr/share/doc/onesixtyone/dict.txt 192.168.1.1
nmap -sU -p 161 --script=snmp-brute 192.168.1.1
```

◈ snmpwalk — Extract Everything

```
snmpwalk -c public -v1 192.168.1.1          # v1, public community
snmpwalk -c public -v2c 192.168.1.1         # v2c
snmpwalk -c public -v2c 192.168.1.1 1.3.6.1.4.1.77.1.2.25  # Windows users OID
```

OID	Data Returned
1.3.6.1.2.1.25.4.2.1.2	Running processes
1.3.6.1.2.1.25.6.3.1.2	Installed software
1.3.6.1.2.1.6.13.1.3	TCP open ports
1.3.6.1.4.1.77.1.2.25	Windows usernames
1.3.6.1.2.1.2.2.1.2	Network interfaces
1.3.6.1.2.1.4.34.1.3	IPv6 addresses

◈ snmpbulkwalk / snmpenum

```
snmp-check 192.168.1.1 -c public
snmpenum.pl 192.168.1.1 public windows.txt
```

▶ 4.4 LDAP Enumeration (Port 389/636)

LDAP on Domain Controllers dumps Active Directory users, groups, OUs, and policies.

```
ldapsearch -x -H ldap://192.168.1.1 -b 'dc=domain,dc=com'
ldapsearch -x -H ldap://192.168.1.1 -b '' -s base '(objectclass=*)'
namingContexts
ldapsearch -x -H ldap://192.168.1.1 -D 'cn=admin,dc=domain,dc=com' -w password -
b 'dc=domain,dc=com' '(objectClass=person)'
```

```
# Using windapsearch
python3 windapsearch.py -d domain.com --dc-ip 192.168.1.1 -U    # All users
python3 windapsearch.py -d domain.com --dc-ip 192.168.1.1 -G    # All groups
python3 windapsearch.py -d domain.com --dc-ip 192.168.1.1 --da  # Domain admins
```

▶ 4.5 SMTP Enumeration (Port 25)

SMTP can be used to enumerate valid email addresses / usernames via VRFY, EXPN, and RCPT TO commands.

```
nc -nv 192.168.1.1 25                    # Manual banner grab
VRFY root                                 # Check if user exists
EXPN postmaster                           # Expand mailing list
RCPT TO:<root@domain.com>                # Alternative check
```

```
smtp-user-enum -M VRFY -U users.txt -t 192.168.1.1
smtp-user-enum -M RCPT -U users.txt -D domain.com -t 192.168.1.1
nmap -p 25 --script=smtp-enum-users --script-args smtp-enum-users.userdb=users.txt 192.168.1.1
```

▶ 4.6 HTTP/Web Enumeration (Port 80/443)

◈ Banner Grabbing

```
curl -I http://192.168.1.1                # HTTP headers
nc -nv 192.168.1.1 80 << 'EOF'
HEAD / HTTP/1.0

EOF
```

◈ Directory Bruteforce

```
gobuster dir -u http://192.168.1.1 -w /usr/share/wordlists/dirb/common.txt
gobuster dir -u http://192.168.1.1 -w /usr/share/seclists/Discovery/Web-Content/raft-large-files.txt -x php,txt,html,bak
feroxbuster -u http://192.168.1.1 -w /usr/share/seclists/Discovery/Web-Content/common.txt
dirb http://192.168.1.1 /usr/share/wordlists/dirb/common.txt
```

◈ Nikto — Web Vulnerability Scanner

```
nikto -h http://192.168.1.1
nikto -h http://192.168.1.1 -Tuning 1234
nikto -h http://192.168.1.1 -o nikto_out.txt
```

◈ WhatWeb / Wappalyzer — Tech Stack ID

```
whatweb http://192.168.1.1
whatweb -a 3 http://192.168.1.1           # Aggression level 3
```

4.7 NetBIOS Enumeration

```
nbtscan 192.168.1.0/24                    # Quick NetBIOS scan
nbtstat -A 192.168.1.1                    # Windows: NetBIOS name table
nmblookup -A 192.168.1.1                  # Linux alternative
```

Code	Type	Meaning
00	UNIQUE	Workstation / Computer name
20	UNIQUE	File & Printer sharing
1D	GROUP	Master browser
1B	UNIQUE	Domain Master Browser
03	UNIQUE	Messenger service

4.8 RPC Enumeration (Port 111/135)

```
rpcinfo -p 192.168.1.1                    # List RPC services (Linux)
rpcclient -U '' -N 192.168.1.1            # Null session RPC
```

Inside rpcclient:

```
srvinfo              # Server info
enumdomusers         # Enumerate domain users
enumdomgroups        # Enumerate groups
querydominfo         # Domain info
netshareenum         # List shares
getdompwinfo         # Password policy
lookupnames admin    # SID for username
lookupsids S-1-5-21-... # Username for SID
```

4.9 FTP Enumeration (Port 21)

```
nmap -p 21 --script=ftp-anon,ftp-bounce,ftp-syst,ftp-banner 192.168.1.1
ftp 192.168.1.1                           # Connect
# Username: anonymous | Password: <blank> or any email
ls -la                                    # List files (within FTP)
get filename.txt                          # Download file
```

[TIP] FTP anonymous login is common on CTFs and old servers. Always try it first!

4.10 SSH Enumeration (Port 22)

```
nc -nv 192.168.1.1 22                     # Grab SSH banner (version)
ssh -v user@192.168.1.1 2>&1 | grep 'Remote protocol'
nmap -p 22 --script=ssh-hostkey,ssh-auth-methods 192.168.1.1
```

```
ssh-audit 192.168.1.1                    # Full SSH audit tool
```

05. TOOLS QUICK REFERENCE

Tool	Purpose	Key Flag / Usage
nmap	Port & service scanning	-A -T4 -p- -sV -sC
masscan	Ultra-fast port scan	--rate=10000 -p1-65535
enum4linux	SMB/NetBIOS enumeration	-a target
smbmap	SMB share mapping	-H target -u user -p pass
crackmapexec	SMB/WinRM automation	smb target --shares
snmpwalk	SNMP enumeration	-c public -v2c target
onesixtyone	SNMP community bruteforce	-c dict.txt target
ldapsearch	LDAP/AD enumeration	-x -H ldap://target
dnsenum	DNS enumeration	target.com
gobuster	Dir/DNS bruteforce	dir -u url -w wordlist
feroxbuster	Fast web dir bruteforce	-u url -w wordlist
nikto	Web vulnerability scan	-h http://target
whatweb	Web tech fingerprint	http://target
rpcclient	Windows RPC enum	-U '' -N target
smtp-user-enum	SMTP user enumeration	-M VRFY -U users.txt -t target
nbtscan	NetBIOS scan	192.168.1.0/24
nc (netcat)	Banner grab / manual probe	-nv target port
dnsrecon	DNS recon & bruteforce	-d domain -t brt

06. MASSCAN — FASTER THAN NMAP

Masscan can scan the entire internet in 6 minutes. Use it for wide network sweeps, then hand off to Nmap for detailed analysis.

```
masscan -p1-65535 192.168.1.0/24 --rate=1000
masscan -p80,443,8080 192.168.1.0/24 --rate=5000 -oG masscan.out
# Combine with nmap:
masscan -p1-65535 192.168.1.1 --rate=10000 | awk '{print $4}' | cut -d'/' -f1 |
sort -u > ports.txt
nmap -p $(cat ports.txt | tr '\n' ',') -sV -sC 192.168.1.1
```

[!] WARNING: Set --rate appropriately. Very high rates can crash network equipment and are detectable.

07. PRACTICAL PENTEST WORKFLOW

▶ Step 1 — Host Discovery

```
nmap -sn 192.168.1.0/24 -oG hosts.txt
arp-scan --localnet
```

▶ Step 2 — Quick Port Scan

```
nmap -T4 --min-rate 5000 -p- 192.168.1.1 -oN quick_ports.txt
```

▶ Step 3 — Detailed Service Scan

```
nmap -sV -sC -p 22,80,443,445 192.168.1.1 -oA detailed
```

▶ Step 4 — Service-Specific Enumeration

- Port 21 → FTP anon login check
- Port 22 → SSH version, auth methods
- Port 25 → SMTP user enumeration
- Port 53 → DNS zone transfer, subdomain brute
- Port 80/443 → Nikto, Gobuster, Whatweb
- Port 139/445 → enum4linux, smbmap, rpcclient
- Port 161 UDP → SNMP walk
- Port 389 → LDAP dump
- Port 3389 → RDP version, NLA check

▶ Step 5 — Vulnerability Correlation

- Map service versions to CVEs (searchsploit, exploit-db)
- Run Nmap vuln scripts: nmap --script=vuln
- Run Nikto on all web ports
- Check for default creds on all management interfaces

08. SEARCHSPLOIT — CVE TO EXPLOIT

searchsploit is the command-line interface for exploit-db.com. Once you have service versions from scanning, find exploits instantly.

```
searchsploit vsftpd 2.3.4
searchsploit apache 2.4.49
searchsploit -t 'smb remote'                # Search in title only
searchsploit -x exploits/linux/remote/17491.c  # Examine exploit
searchsploit -m exploits/linux/remote/17491.c  # Copy to current dir
```

```
searchsploit --nmap output.xml                # Auto-search from Nmap XML
```

09. QUICK COMMAND CHEATSHEET

Scenario	Command
Find all live hosts	nmap -sn 192.168.1.0/24
Fast full port scan	nmap -p- --min-rate 10000 192.168.1.1
Service + script scan	nmap -sV -sC 192.168.1.1
All format output	nmap -oA output 192.168.1.1
SMB null session	smbclient -L //192.168.1.1 -N
Full SMB enum	enum4linux -a 192.168.1.1
SNMP walk	snmpwalk -c public -v2c 192.168.1.1
DNS zone transfer	dig axfr @ns1.target.com target.com
Web directory scan	gobuster dir -u http://192.168.1.1 -w /usr/share/wordlists/dirb/common.txt
Web vuln scan	nikto -h http://192.168.1.1
SMTP user enum	smtp-user-enum -M VRFY -U users.txt -t 192.168.1.1
RPC null session	rpcclient -U '' -N 192.168.1.1
Search for exploit	searchsploit vsftpd 2.3.4
Banner grab	nc -nv 192.168.1.1 80
FTP anonymous	ftp 192.168.1.1 (user: anonymous)

10. IDS/IPS EVASION TECHNIQUES

Technique	Nmap Flag	Effect
Packet Fragmentation	-f / --mtu 8	Split packets to bypass DPI
Decoy Scanning	-D RND:5	Flood IDS with fake source IPs
Slow Scan	-T0 / -T1	Stay under IDS threshold
Source Port Spoof	--source-port 53	Impersonate trusted services
Random Host Order	--randomize-hosts	Avoid sequential scan detection
Data Padding	--data-length 30	Add noise to fingerprint
Idle/Zombie Scan	-sI zombie_ip	Completely blind scan
Proxy Chains	proxychains nmap	Route through proxy chain

```
# Idle scan (completely stealthy — uses zombie host)
nmap -sI 10.0.0.5:80 192.168.1.1
```

```
# Full evasion combo
nmap -sS -T1 -f --mtu 16 -D RND:10 --source-port 53 --data-length 20 -Pn
192.168.1.1
```

11. EXAM & FIELD NOTES

▶ CEH / OSCP Key Points

- SYN scan (-sS) is the most common and stealthy TCP scan — doesn't complete handshake
- UDP scan (-sU) is essential — DNS (53), SNMP (161), TFTP (69), NTP (123) run on UDP
- Null, FIN, and Xmas scans work differently on Windows vs Unix — Windows returns RST for all, making open/closed indistinguishable
- ACK scan doesn't find open ports — it maps firewall rules
- SNMP v1/v2 use community strings as 'passwords'. Default is 'public' (read) and 'private' (write)
- Zone transfer is a critical DNS misconfiguration — always test it
- NetBIOS code 20 (hex) = File and Printer sharing — high value target

▶ Common Default Credentials to Try

Service	Username	Password
FTP	anonymous	(blank) or any@email.com
Telnet	admin	admin / password
SSH	root	toor / root / admin
HTTP Basic Auth	admin	admin / password / 1234
SNMP	(N/A)	public / private / community
MySQL	root	(blank) / root / toor
MSSQL	sa	(blank) / sa / password
RDP	Administrator	password / admin / 1234

⚠ **LEGAL REMINDER:** All techniques in these notes must only be used on systems you own or have explicit written permission to test. Unauthorized computer access is a serious criminal offense. Use this knowledge responsibly and ethically.